

INCIDENT RESPONSE REPORT

SOC165 — SQL Injection Attack

Possible SQL Injection Payload Detected — WebServer1001

Analyst: Mehenni May · Date: 26 February 2026 · Classification: TLP:WHITE · Platform: LetsDefend

ALERT
SOC165

VERDICT
TRUE POSITIVE

OUTCOME
ATTACK FAILED

SEVERITY
HIGH

01 EXECUTIVE SUMMARY

This report documents the investigation of alert SOC165 — a high-severity SIEM rule triggered by a SQL injection payload detected in an inbound HTTP GET request targeting the internal web application server WebServer1001. The investigation followed the LetsDefend Web Attack analysis playbook and confirmed the event as a true positive external attack. The attack was determined to be unsuccessful based on HTTP response analysis and endpoint command history review.

Category	Summary
What happened	An external IP address (167.99.169.17) sent a GET request to the internal search endpoint on WebServer1001 (172.16.17.18) containing a classic SQL injection tautology payload: " OR 1 = 1 -- -. The SIEM rule SOC165 triggered on the presence of 'OR 1 = 1' in the requested URL. The request was permitted by the network device — there was no blocking rule in place.
Attack type	SQL Injection — Boolean-based tautology attack. The attacker injected a condition that always evaluates to true in order to bypass authentication or extract all rows from a database query. The payload was delivered via URL parameter in a GET request to the /search/ endpoint.
Risk / severity	HIGH — the alert level was classified as High by the SIEM rule. Although the attack did not succeed, the request was permitted by the network device and reached the application. An unpatched or differently configured application could have been compromised.
Was it successful?	NO. The server returned HTTP 500 (Internal Server Error) with a consistent response size of 948 bytes across all payload variations. A successful SQL injection would return HTTP 200 with variable response sizes containing extracted data. The uniform 500 response indicates the server errored on the malformed input rather than processing it.
False positive?	NO. The request originated from an external DigitalOcean IP flagged as malicious by 4/93 VirusTotal vendors. No planned test or penetration test notification was found in the mailbox. The alert is a confirmed true positive.
Actions taken	Source IP investigated via WHOIS, AbuseIPDB, VirusTotal, and Cisco Talos. Endpoint command history reviewed on the target device — no suspicious

commands or post-exploitation activity found. Traffic direction confirmed as Internet to Company Network. Alert closed as True Positive — attack failed.

02 ALERT DETAILS & INITIAL TRIAGE

2.1 SIEM Alert

Event ID	115
Alert rule	SOC165 — Possible SQL Injection Payload Detected
Severity	High
Category	Web Attack
Alert level	Security Analyst
Event time	February 25, 2022 11:34 AM
Trigger reason	Requested URL contains OR 1 = 1
Device action	Allowed — request was not blocked by the network device
Hostname	WebServer1001
Destination IP	172.16.17.18 (internal web application server)
Source IP	167.99.169.17 (external — DigitalOcean, Santa Clara, US)
Request method	GET
Protocol / Port	HTTPS / 443
Requested URL	https://172.16.17.18/search/?q=%22%20OR%201%20%3D%201%20--%20-
User-Agent	Mozilla/5.0 (Windows NT 6.1; WOW64; rv:40.0) Gecko/20100101 Firefox/40.1
Response status	HTTP 500 — Internal Server Error
Response size	948 bytes

Figure 1 – LetsDefend SIEM: SOC165 Alert Overview — SQL Injection Payload, High Severity

Event ID	115
Event Time	Feb. 25, 2022, 11:34 AM
Alert Rule	SOC165 - Possible SQL Injection Payload Detected
Severity	High
Category	Web Attack
Alert Level	Security Analyst
Device Action	Allowed
Hostname	WebServer1001
Destination IP	172.16.17.18
Source IP	167.99.169.17
Request Method	GET
Protocol / Port	HTTPS / 443
Requested URL	https://172.16.17.18/search/?q=%22%20OR%201%20%3D%201%20--%20-
User-Agent	Mozilla/5.0 (Windows NT 6.1; WOW64; rv:40.0) Gecko/20100101 Firefox/40.1
Response Status	HTTP 500 - Internal Server Error
Response Size	948 bytes

Figure 2 – Full Event Log: Source IP, Destination, URL, Response Status 500 / Size 948

500

UNDERSTANDING WHY THE ALERT TRIGGERED

The first step in the LetsDefend playbook requires the analyst to understand the specific trigger condition before beginning deeper investigation. This prevents wasted effort and provides the correct analytical frame.

3.1 Rule Analysis

The string ' OR 1 = 1 ' is a classic SQL injection technique. When injected into a query, it makes the WHERE clause always evaluate to true, bypassing authentication or returning all table rows regardless of the intended filter.

3.2 Payload Decoding

The URL parameter value was percent-encoded. Decoding the raw URL confirms the SQL injection payload directly. The decoded string was extracted using an online URL decoder.

https://172.16.17.18/search/?q=" OR 1 = 1 -- -

Opening quote	" — closes the intended string parameter in the SQL query
OR 1 = 1	Tautological condition — always evaluates to true, bypassing any WHERE clause filter
-- -	SQL comment syntax — comments out the rest of the original query, preventing syntax errors
Target endpoint	/search/ — the web application's search function, which likely passes the q= parameter directly into a SQL query
Technique	In-band SQL Injection — Boolean-based tautology. If successful, the server would return all rows from the query rather than the filtered subset.

Figure 3 – LetsDefend Playbook: Understand Why the Alert Was Triggered

Understand Why the Alert Was Triggered

In order to perform a better analysis and to determine whether the triggered alert is false positive, it is first necessary to understand why the rule was triggered. Instead of starting the analysis directly, first understand why this rule was triggered.

- Examine the rule name. Rule names are usually created specifically for the attack to be detected. By examining the rule name, you can understand which attack you are facing.
- Detect between which two devices the traffic is occurring. It's a good starting point to understand the situation by learning about the direction of traffic, what protocol is used between devices, etc.

Next

Figure 4 – URL Decoder: Encoded Payload Decoded to '" OR 1 = 1 -- -'

URL Decoder/Encoder

https://172.16.17.18/search/?q=" OR 1 = 1 -- -

04 PLANNED TEST CHECK

Penetration tests and attack simulation tools can generate traffic identical to real attacks. The playbook requires the analyst to check whether the triggering activity was the result of authorised testing before escalating. This step prevents false positive escalations that waste response resources.

4.1 Methodology

The Email Security module was searched for any prior notification to the WebServer1001 hostname, the IP address 172.16.17.18, or the source IP 167.99.169.17. Additionally, the source IP 167.99.169.17 was checked against known attack simulation product naming conventions (Verodin, AttackIQ, Picus).

4.2 Findings

Email notification found?	No — no authorised test notification was found in the mailbox for the relevant device or IP addresses
Email found in inbox	An unrelated email from support@linuxhelp.me about a Linux script (file_cleanup_2024.sh) was the only relevant item — this is not a penetration test notification and does not correspond to the attack timestamp or the source IP
Attack simulation hostname?	No — source IP 167.99.169.17 resolves to api.ecreaup.pro (DigitalOcean), not an attack simulation platform
Conclusion	NOT a planned test — the activity is real, unsolicited external attack traffic

Figure 5 – LetsDefend Playbook: Check If It Is a Planned Test

Check If It Is a Planned Test

Penetration tests or attack simulation products can trigger False Positive alarms if the rules are not set correctly. Check whether the malicious traffic is the result of a planned test.

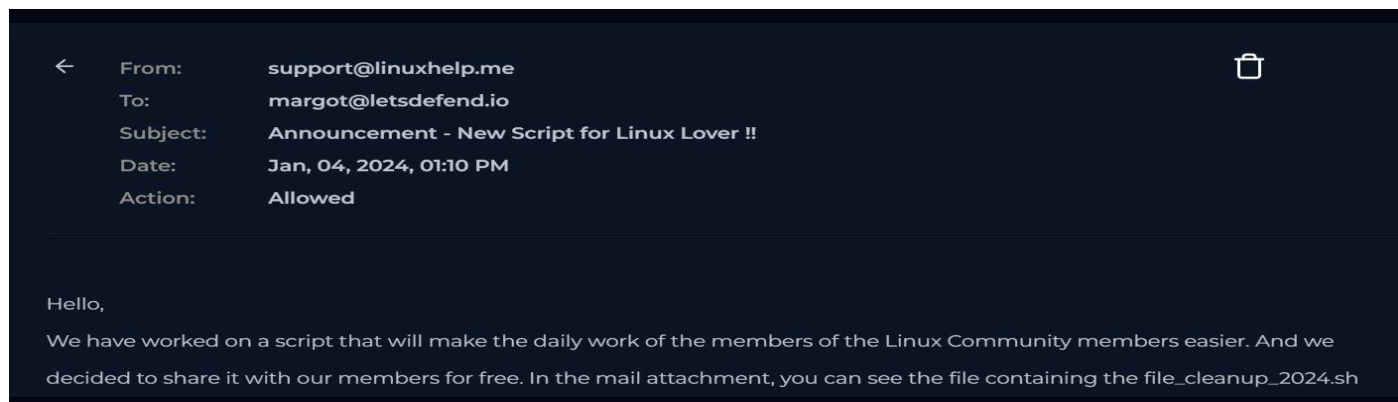
- Check if there is an email showing that there will be planned work by searching for information such as hostname, username, IP address on the mailbox.
- Check if the device generating malicious traffic belongs to attack simulation products. If the Hostname contains the name of Attack Simulation products (such as Verodin, AttackIQ, Picus...), these devices belong to Attack Simulation products within the framework of LetsDefend simulation and it is a planned work.

Is the malicious traffic caused by a planned test?

Not Planned

Planned

Figure 6 – Email Inbox Search: No Planned Test Notification Found (Unrelated Script Email Only)



05 SOURCE IP INTELLIGENCE

The source IP 167.99.169.17 was investigated across four threat intelligence platforms to characterise the attacker's infrastructure and assess prior abuse history.

5.1 WHOIS

IP address	167.99.169.17
CIDR range	167.99.0.0/16
Net name	DIGITALOCEAN-167-99-0-0
Organisation	DigitalOcean, LLC (ASN AS14061)
Registered	2017-11-10
Country	United States
Abuse contact	https://www.digitalocean.com/company/contact/#abuse
Assessment	DigitalOcean is a cloud hosting provider commonly used to host attacker infrastructure — the IP is a rented VPS, not a residential or corporate address

Figure 7 – WHOIS: 167.99.169.17 — DigitalOcean LLC, ASN AS14061, US

167.99.169.17

WHOIS Information

Whois

Reverse IP

Diagnostics

Discover more

Domain Registrar Comparison

Domain Management Platform

Network security hardware

Cybersecurity software

Secure Data Access

DNS Record Lookup

IP Whois

NetRange:

167.99.0.0 - 167.99.255.255

CIDR:

167.99.0.0/16

NetName:

DIGITALOCEAN-167-99-0-0

Nethandle:

NET-167-99-0-0-1

Parent:

NET167 (NET-167-0-0-0-0)

NetType:

Direct Allocation

OriginAS:

Organization:

DigitalOcean, LLC (DO-13)

RegDate:

2017-11-10

Updated:

2020-04-03

Comment:

Routing and Peering Policy can be found at <https://www.as14061.net>

Comment:

Comment:

Please submit abuse reports at <https://www.digitalocean.com/company/contact/#abuse>

Ref:

<https://rdap.arin.net/registry/ip/167.99.0.0>

OrgName:

DigitalOcean, LLC

OrgId:

DO-13

Address:

105 Edgeview Drive, Suite 425

City:

Broomfield

StateProv:

CO

PostalCode:

80021

Country:

US

5.2 Reverse DNS

IP address	167.99.169.17
PTR record	api.ecreaup.pro
FWD/REV match	Yes (confirmed in Cisco Talos)
Assessment	api.ecreaup.pro is the hostname associated with this IP — this is a non-residential subdomain consistent with attacker-controlled or compromised cloud infrastructure

Figure 8 – Reverse DNS: 167.99.169.17 → api.ecreaup.pro (1 hostname found)

Enter an IP address...

Search

167.99.169.17

Reverse DNS Lookup

Whois

Reverse IP

Diagnostics

Reverse DNS Results

Found 1 hostname associated with this IP address:

Hostname	WHOIS	DNS
api.ecreaup.pro	View	View

5.3 Domain RDAP — ecreaup.pro

Domain	ecreaup.pro
Registrar	HOSTINGER operations, UAB (IANA ID 1636)
Abuse contact	abuse@hostinger.com +1-212-252-2172
IP (RDAP)	216.198.79.1
Assessment	Hostinger is a budget web hosting registrar frequently associated with low-cost, short-term domain registrations used in malicious campaigns

Figure 9 – RDAP: ecreaup.pro — Registered at Hostinger operations, UAB


[Report IP](#)
[Bulk Checker](#)
[Bulk Reporter](#)
[Pricing](#)
[Docs](#)
[IP Utilities](#)
[Contact](#)
[More](#)

[Login](#)
[Sign Up](#)

0

167.99.169.17 was found in our database!

This IP was reported **14,851** times. Confidence of Abuse is **0%**: ?

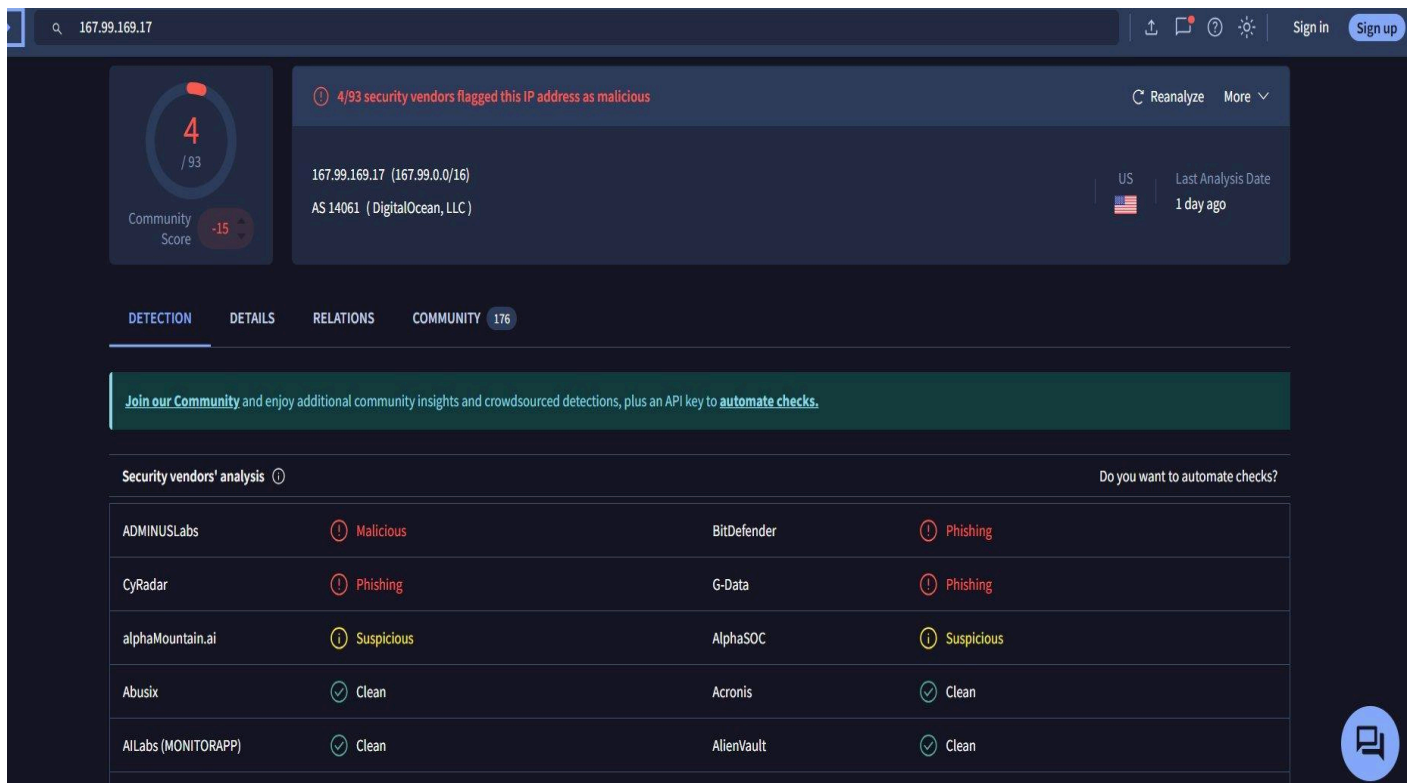
0%

ISP	DigitalOcean, LLC
Usage Type	Data Center/Web Hosting/Transit
ASN	AS14061
Hostname(s)	api.ecreaup.pro
Domain Name	digitalocean.com
Country	 United States of America
City	Santa Clara, California

5.5 VirusTotal

IP address	167.99.169.17
Detection	4 / 93 security vendors flagged as malicious
Community score	-15 (negative community consensus)
Last analysis	1 day ago
Detections	ADMINUSLabs: Malicious BitDefender: Phishing CyRadar: Phishing G-Data: Phishing
Suspicious flags	alphaMountain.ai: Suspicious AlphaSOC: Suspicious
ASN	AS14061 (DigitalOcean, LLC)
Assessment	Multiple established security vendors flag this IP as malicious/phishing. The negative community score and detection history confirm this is a known malicious IP.

Figure 11 – VirusTotal: 4/93 Vendors Flag 167.99.169.17 as Malicious — Community Score -15



5.6 Cisco Talos

IP address	167.99.169.17
Location	Santa Clara, United States
Network owner	Digital Ocean Inc.
Sender IP reputation	Neutral
Web reputation	Neutral
Talos block list	No (status: Expired — previously listed)
Content category	No established content categories
Assessment	Talos rates the IP as neutral. The expired block list status is notable — this IP was previously blocked by Talos, suggesting historical abuse, with the listing having since expired.

Figure 12 – Cisco Talos: 167.99.169.17 — Neutral Reputation, DigitalOcean, Previously Block-Listed (Expired)

LOCATION DATA

SANTA CLARA, UNITED STATES

OWNER DETAILS

IP ADDRESS167.99.169.17

FWD/REV DNS MATCHYes

HOSTNAME-

DOMAIN-

NETWORK OWNERDIGITAL OCEAN INC.

CONTENT DETAILS

CONTENT CATEGORYNo established content categories

Think these category details are incorrect?

Submit Content Categorization Ticket

REPUTATION DETAILS

SENDER IP REPUTATION
 Neutral

Submit Sender IP Reputation Ticket

WEB REPUTATION
 Neutral

Submit Web Reputation Ticket

EMAIL VOLUME DATA

	LAST DAY	LAST MONTH
EMAIL VOLUME	0.0	0.0
VOLUME CHANGE	0%	

BLOCK LISTS

TALOS SECURITY INTELLIGENCE BLOCK LIST

ADDED TO THE BLOCK LIST	
No	
STATUS	EXPIRED

5.7 IP Intelligence Summary

Platform	Result	Key Finding	Confidence
WHOIS	DigitalOcean LLC	Cloud VPS — rented attacker infra	HIGH
Reverse DNS	api.ecreaup.pro	Attacker-controlled subdomain	HIGH
AbuseIPDB	14,851 reports	High historical abuse volume	HIGH
VirusTotal	4/93 Malicious (score -15)	Multiple vendors: Malicious/Phishing	HIGH
Cisco Talos	Neutral (expired block)	Previously listed — abuse history	MEDIUM

06 TRAFFIC DIRECTION & HTTP TRAFFIC ANALYSIS

6.1 Traffic Direction

The LetsDefend playbook requires the analyst to confirm the direction of traffic before examining HTTP content. This determines the appropriate investigative lens — inbound attacks from the internet require infrastructure investigation; outbound anomalies suggest compromise.

Source	167.99.169.17 — external internet IP (DigitalOcean)
Destination	172.16.17.18 — internal company web server (WebServer1001)

Direction	Internet → Company Network
Assessment	Inbound attack from an external threat actor targeting an internal asset. The appropriate response is to investigate the attacker's infrastructure and assess whether the web server was compromised.

Figure 13 – LetsDefend Playbook: Collect Data — IP Intelligence Gathering Steps

Collect Data

Gather some information that can be gathered quickly to get a better understanding of the traffic. These can be summarized as follows.

- Ownership of the IP addresses and devices.
 - If the traffic is coming from outside (Internet);
 - Ownership of IP address (Static or Pool Address? Who owns it? Is it web hosting?)
 - Reputation of IP Address (Search in VirusTotal, AbuseIPDB, [Cisco Talos](#))
 - If the traffic is coming from company network;
 - Hostname of the device
 - Who owns the device (username)
 - Last user logon time

Next

Figure 14 – Traffic Direction: Internet → Company Network (Selected)

What Is the Direction of Traffic?

Select the direction of malicious traffic from the available options below.

Format: Source -> Destination

Company Network → Company Network

Company Network → Internet

Internet → Company Network

The LetsDefend playbook instructs the analyst to examine all HTTP request fields — not only the URL — for web attack payloads. The attack in this case was delivered exclusively via the URL query parameter. All HTTP fields were examined.

Protocol	HTTPS (port 443) — encrypted transport
Method	GET — payload delivered via URL query string
Endpoint	/search/ — web application search function
Query parameter	q= — the search query parameter targeted for injection
Payload (raw)	%22%20OR%201%20%3D%201%20--%20-
Payload (decoded)	" OR 1 = 1 -- - (Boolean-based tautology + comment injection)
User-Agent	Mozilla/5.0 (Windows NT 6.1; WOW64; rv:40.0) Gecko/20100101 Firefox/40.1
UA assessment	Firefox 40.1 was released in 2015 — this is an outdated browser string often used in automated attack tools to appear legitimate
Device action	Permitted — no WAF or IPS rule blocked this request
Response code	HTTP 500 — Internal Server Error
Response size	948 bytes — consistent across all payload variations

The request was PERMITTED by the network device — there was no blocking rule in place for this type of payload. The attack reached the web application directly. The application's own error handling (producing HTTP 500) was the only control that prevented successful exploitation.

Figure 15 – LetsDefend Playbook: Examine HTTP Traffic

Examine HTTP Traffic

Check the traffic content for any suspicious conditions such as web attack payloads (SQL Injection, XSS, Command Injection, IDOR, RFI/LFI).

Examine all the fields in the HTTP Request. Since the attackers do not only attack through the URL, all the data from the source must be examined to understand whether there is really a cyber attack.

You can review the Web Attacks 101 tutorial for information about attacks on web applications and how to detect these attacks.

Figure 16 – Event Detail Close-Up: Response Status 500, Response Size 948 bytes

Event	
Request URL	https://172.16.17.180/search?q=7022702001702017020703...
User-Agent	Mozilla/5.0 (Windows NT 6.1; WOW64; rv:40.0) Gecko/20100101 Firefox/40.0
Request Method	GET
Device Action	Permitted
HTTP Response Size:	948
HTTP Response Status	500

07 ENDPOINT SECURITY CHECK

The LetsDefend playbook notes that SQL injection attacks can lead to command execution on the web server through database functions such as xp_cmdshell. Endpoint Security on the target device was reviewed to detect any anomalous process or command execution that may indicate post-exploitation activity.

7.1 Target Device

Hostname	Margot (associated with the investigation environment)
Domain	LetsDefend
IP address	172.16.17.180
OS	Ubuntu 20.04.02 (64-bit)
Primary user	Analyst
Client/Server	Client
Last login	January 04, 2024 01:14 PM

Figure 17 – Endpoint Security: Host Information — Margot (Ubuntu 20.04, 172.16.17.180)

Host Information

Hostname:

Margot

Domain:

LetsDefend

IP Address:

172.16.17.180

Bit Level:

64

OS:

Ubuntu 20.04.02

Primary User:

Analyst

Client/Server:

Client

Last Login:

Jan, 04, 2024, 01:14 PM

Action

Containment:

Remote Access:

Go to Lab

7.2 Process & Command History

Endpoint Security was reviewed for any suspicious commands launched around the time of the SQL injection attempt. The command history on the device showed only legitimate system maintenance activity.

Event Time	Command Line
2024-01-04 13:24:47	/bin/sh /etc/cron.monthly/0anacron
2024-01-04 13:24:47	/bin/sh -c run-parts --report /etc/cron.monthly
2024-01-04 13:20:53	/bin/sh /usr/lib/apt/apt.systemd.daily install
2024-01-04 13:20:53	/bin/sh /usr/lib/apt/apt.systemd.daily install
2024-01-04 13:20:53	/bin/sh /usr/lib/apt/apt.systemd.daily install

Command history contains only legitimate system maintenance commands: cron monthly execution (0anacron) and APT daily maintenance (apt.systemd.daily install). No suspicious commands, no database CLI tools, no network utilities, and no signs of xp_cmdshell or equivalent post-exploitation activity. The endpoint shows no evidence of successful SQL injection-based command execution.

Additionally, Endpoint Security recorded one process event at 2024-01-04 13:19:51 — Process ID 2631, process name 'dash', command line 'sh file_cleanup_2024.sh', with target process 'sudo apt update'. This process was spawned from a script received via email (file_cleanup_2024.sh from support@linuxhelp.me). This is unrelated to the SQL injection alert and does not represent post-exploitation activity.

Figure 18 – Endpoint Security: Process Tree — sh file_cleanup_2024.sh / sudo apt update (Unrelated)

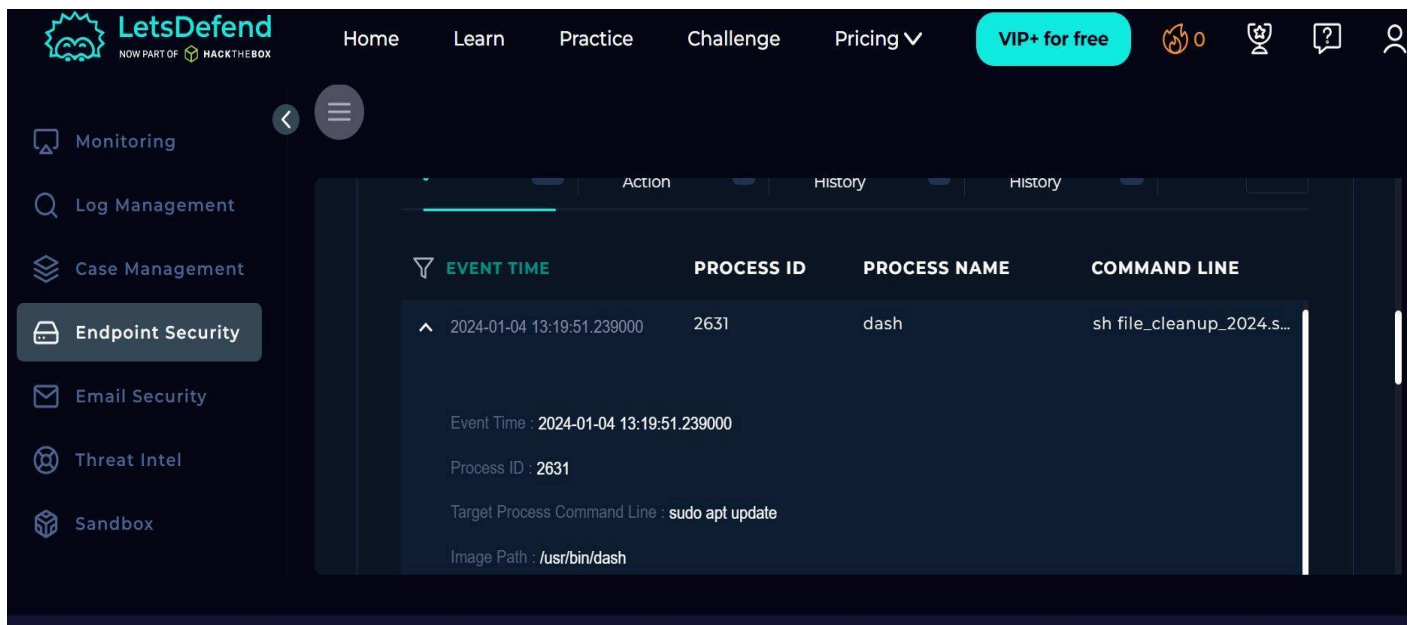


Figure 19 – Command History: All Commands are Legitimate System Maintenance (cron / apt)

EVENT TIME	COMMAND LINE
2024-01-04 13:24:47	/bin/sh /etc/cron.monthly/0anacron
2024-01-04 13:24:47	/bin/sh -c run-parts --report /etc/cron.monthly
2024-01-04 13:20:53	/bin/sh /usr/lib/apt/apt.systemd.daily install
2024-01-04 13:20:53	/bin/sh /usr/lib/apt/apt.systemd.daily install
2024-01-04 13:20:53	/bin/sh /usr/lib/apt/apt.systemd.daily install

08 ATTACK SUCCESS DETERMINATION

The LetsDefend playbook instructs the analyst to determine whether the attack was successful using HTTP response indicators specific to the attack type. For SQL injection, the key indicators are the HTTP response status code and the response body size.

8.1 HTTP Response Analysis

Indicator	Observed Value	Interpretation
HTTP Response Status	500 — Internal Server Error	The server encountered an unhandled error processing the malformed SQL input. It did not return data — it returned an error page.

HTTP Response Size	948 bytes — consistent across all payload variations	A successful SQL injection would produce variable response sizes as different data volumes are extracted. A fixed 948-byte response indicates a static error page, not extracted data.
Command execution	No suspicious commands on endpoint	Endpoint command history shows only legitimate system processes. No database CLI tools, shells spawned by the web server, or privilege escalation attempts were observed.

8.2 Verdict

TRUE POSITIVE — the alert correctly identified a genuine SQL injection attempt from an external threat actor. The attack is confirmed real and not a planned test.

ATTACK FAILED — the server returned HTTP 500 with a consistent 948-byte response across all payload variations. No database data was extracted. No post-exploitation activity was found on the endpoint. The application's error handling prevented successful exploitation, though the absence of a WAF or blocking rule represents a significant defensive gap.

Figure 20 – LetsDefend Playbook: Check Whether the Attack Was Successful

Check Whether the Attack Was Successful

Investigate whether the attack was successful. Detection mechanisms vary according to the attack type. Some tips that can help with your investigation;

- In Command Injection attacks, you can understand whether the attack was successful by looking at the "Command History" of the relevant device via Endpoint Security. In SQL Injection attacks, attackers can run commands on the device with the help of functions such as "xp_cmdshell". For this reason, you may need to look at the "Command History" in SQL Injection attacks.
- You can guess by looking at the HTTP Response size in SQL Injection and IDOR attacks.

You can access the Web Attacks 101 training below, in which we explain how you can understand whether the attack is successful or not according to the attack type.

09 MITRE ATT&CK® MAPPING

ID	Name	Tactic	Evidence	Detection
----	------	--------	----------	-----------

T1190	Exploit Public-Facing Application	Initial Access	SQL injection payload in GET request to /search/?q= on WebServer1001 (172.16.17.18).	WAF rule: block requests with SQL keywords (OR, UNION, SELECT, INSERT, --, etc.) in URL parameters. Alert on HTTP 500 from web endpoints after parameter injection patterns.
T1059	Command and Scripting Interpreter	Execution (attempted)	SQL injection via boolean tautology — intended to execute arbitrary SQL. No command execution confirmed on endpoint.	Monitor for web server processes spawning unexpected child processes (e.g., cmd.exe, bash, sh called from application user context).
T1589.002	Gather Victim Network Information	Reconnaissance	Attacker targeted a specific internal endpoint (/search/) — indicates prior knowledge of or scanning of the web application surface.	Alert on sequential 4xx/5xx responses from a single external IP across multiple web endpoints (web scanning pattern).
T1071.001	Application Layer Protocol: Web Protocols	Command & Control (N/A)	Attack delivered over HTTPS (port 443) — encrypted transport used to blend with legitimate web traffic.	Enforce TLS inspection at the perimeter to allow content-level analysis of encrypted web traffic.

10 RISK ASSESSMENT

Dimension	Rating	Reasoning
Likelihood of future attempt	HIGH	The source IP has 14,851 historical abuse reports and is flagged by multiple threat intel platforms. The attacker specifically targeted the /search/ endpoint with a known SQL injection payload, indicating intent and awareness of the application structure. Further attempts are probable.
Technical impact (this event)	LOW	The attack failed — HTTP 500 confirms no data was extracted and no command execution occurred. The application's error handling acted as an unintentional control.
Potential impact (if successful)	HIGH	A successful SQL injection on the /search/ endpoint could result in full database read access, authentication bypass, data exfiltration, and potentially server-level command execution via database stored procedures.
Business impact (this event)	LOW	No data was exfiltrated, no service was disrupted, and no user accounts were compromised. Impact is limited to the alert triggering analyst investigation time.
Overall risk	MEDIUM	The attack failed, but the absence of a WAF or input validation rule means the same attack could succeed if the application is updated with a new vulnerable endpoint. The permitting device action and lack of blocking represent a systemic gap requiring remediation.

11 RECOMMENDATIONS

#	Priority	Action
---	----------	--------

1	HIGH	Block source IP 167.99.169.17 at the perimeter firewall and email gateway immediately. This IP has 14,851 historical abuse reports and has been flagged as malicious by multiple threat intelligence vendors.
2	HIGH	Deploy or tune a Web Application Firewall (WAF) rule to detect and block SQL injection patterns in URL parameters. At minimum, create a signature rule blocking requests where query parameters contain SQL keywords (OR, UNION, SELECT, INSERT, DROP, --, /*, etc.).
3	HIGH	Conduct a code review of the /search/ endpoint to identify whether the SQL query is parameterised. If string concatenation is used to construct the query, refactor to use prepared statements or parameterised queries — this eliminates the SQL injection vulnerability at the application layer.
4	MEDIUM	Enable input validation on all user-controlled parameters in the web application. Reject or sanitise input containing SQL-significant characters (quotes, hyphens, semicolons) before they reach the database layer.
5	MEDIUM	Configure the SIEM or WAF to alert on multiple HTTP 500 responses from a single external source IP within a defined time window — this pattern is indicative of automated injection scanning.
6	MEDIUM	Block the DigitalOcean ASN range (AS14061 / 167.99.0.0/16) at the perimeter if the web application does not have a legitimate business requirement to serve DigitalOcean data centre traffic. Cloud VPS ranges are a common attack source and have minimal legitimate residential use.
7	LOW	Investigate the ecreaup.pro domain and api.ecreaup.pro hostname further — this may be a compromised server or purpose-built attack infrastructure. Submit an abuse report to DigitalOcean (https://www.digitalocean.com/company/contact/#abuse).
8	LOW	Close alert EventID 115 as True Positive — Attack Failed. Update SIEM/SOAR case status. Retain all investigation artefacts for threat hunting correlation.

12 INDICATORS OF COMPROMISE — IOC APPENDIX

Type	Value	Context	Action
IP	167.99.169.17	Attack source — DigitalOcean VPS (AS14061), 14,851 abuse reports, 4/93 VT detections	Block at perimeter
Domain	ecreaup.pro	PTR record for 167.99.169.17 — attacker-controlled or compromised infrastructure	Monitor / block
Hostname	api.ecreaup.pro	Reverse DNS hostname of attack source IP	Monitor / block
IP range	167.99.0.0/16	DigitalOcean AS14061 range — consider blocking if no business need for this range	Review / block
URL	/search/?q=%22%20OR%201%20%3D%201%20--%20-	SQL injection payload in GET request to WebServer1001	Add WAF signature

Payload	" OR 1 = 1 -- -	Decoded SQL injection tautology — Boolean bypass + SQL comment injection	WAF signature
User-Agent	Mozilla/5.0 (Windows NT 6.1; WOW64; rv:40.0) Gecko/20100101 Firefox/40.1	Outdated browser UA string — common in automated scanners	Correlate
Event ID	SOC165 / EventID 115	SIEM alert — SQL injection payload in URL, WebServer1001, Feb 25 2022 11:34 AM	True Positive

13 LESSONS LEARNED

#	Area	Lesson
1	HTTP 500 = Attack Failed (for SQL Injection)	In SQL injection investigations, HTTP 500 with a consistent response size is a reliable indicator that the server errored on the malformed input rather than processing it. A successful extraction returns HTTP 200 with variable response sizes reflecting the volume of returned data. Always check both status code and body size, not just the status code alone.
2	Response Size is a Key SQL Injection Success Indicator	The response size (948 bytes consistent across payload variations) is as important as the status code. A successful SQL injection tautology attack returns all rows from a query — the response body would grow proportionally to the data extracted. Uniform response sizes indicate uniform error pages, not data.
3	Permitted ≠ Blocked — Gateway Action Matters	The device action was 'Permitted' — the network device did not block the request. A clean sandbox or AV result does not mean the request was blocked. Always check the Device Action field. In this case, the only thing that prevented exploitation was the application's own error handling, not any security control.
4	Cloud VPS IPs Deserve Elevated Scrutiny	The source IP was a DigitalOcean VPS with a 14,851-report abuse history. Cloud provider IP ranges (DigitalOcean, Vultr, Linode, AWS lightsail) are disproportionately represented in attack traffic because they are cheap, easy to provision, and trivially disposable. Treat all inbound traffic from cloud VPS ranges with elevated suspicion by default.
5	URL Decode Before Analysing Payloads	The raw payload (%22%20OR%201%20%3D%201%20--%20-) is not immediately readable. URL-decoding is a mandatory first step in HTTP traffic analysis. Always decode URL-encoded values before characterising the payload or assessing its intent.
6	Endpoint Check is Not Optional for Web Attacks	Even when HTTP response codes indicate failure, endpoint security must still be reviewed. A SQL injection could lead to xp_cmdshell execution or out-of-band interactions not reflected in the HTTP response code. The clean command history in this case elevated confidence that no post-exploitation occurred beyond what the HTTP logs showed.